

Cybersecurity Home Lab

Lab 4: Windows Event Log Detection – RDP Brute Force via Splunk SIEM

Author: Mohamed Navid N | Date: 30 June 2026 | Platform: Splunk Enterprise 10.4.0

1. Objective

This lab demonstrates how to detect failed Windows logon attempts (brute-force attacks) against a Windows 11 host using native Windows Security Event Logs ingested into Splunk Enterprise. The key events monitored are Event ID 4625 (failed logon) and Event ID 4624 (successful logon), generated by a real RDP brute-force attack from a Kali Linux attacker machine.

2. Lab Environment

The lab uses a VirtualBox host-only network topology:

- Windows 11 Host (Victim + Splunk): 192.168.56.1 (Navid-Desktop) — Splunk Enterprise 10.4.0 running locally
- Kali Linux (Attacker): 192.168.56.101 — Hydra v9.6 used for RDP brute force
- Network: VirtualBox Host-Only Adapter (192.168.56.0/24), same as Labs 1-3

Splunk Enterprise was already configured from Lab 3 with the main index active. Remote Desktop Protocol (RDP) was enabled on the Windows 11 host specifically for this lab scenario.

3. Audit Policy Configuration

3.1 Opening Local Security Policy

The Windows audit policy was configured to log both successful and failed logon attempts to the Security event log. This was done via the Local Security Policy editor (secpol.msc):

- Pressed Win + R, typed secpol.msc and clicked OK
- Navigated to: Security Settings → Advanced Audit Policy Configuration → System Audit Policies → Logon/Logoff
- Opened Audit Logon and enabled both Success and Failure checkboxes
- Ran gpupdate /force from an elevated Command Prompt to apply the policy immediately

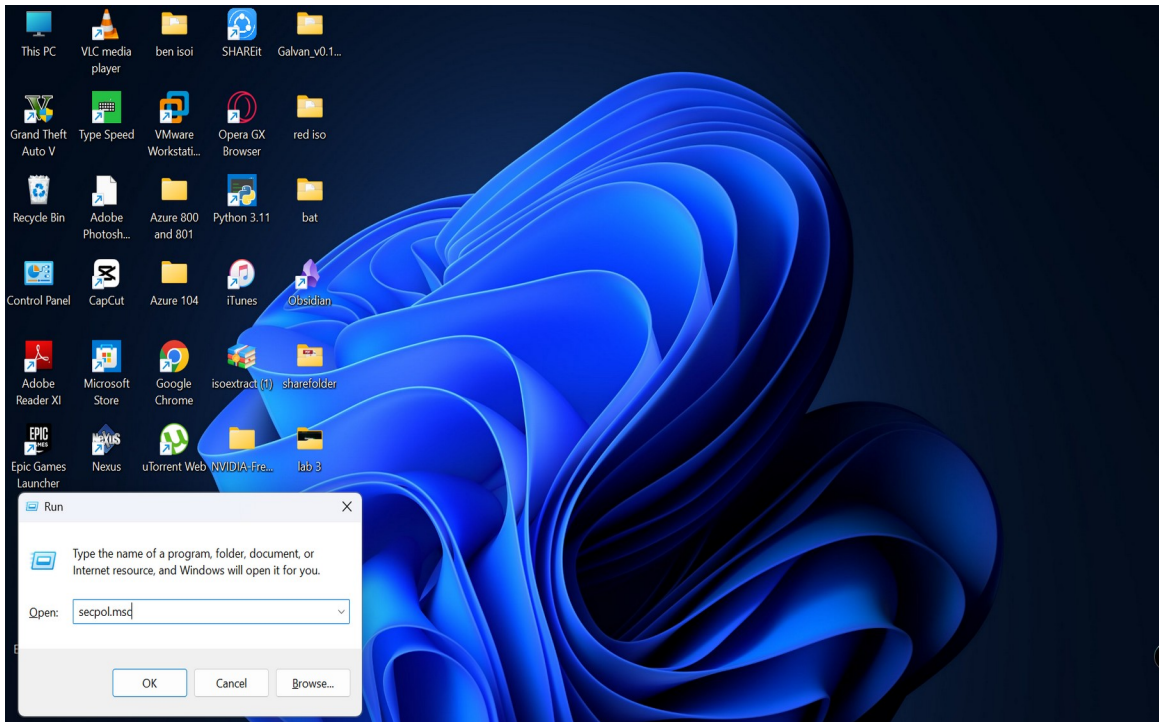


Figure 1: Opening Local Security Policy via Run dialog (secpol.msc)

3.2 Audit Logon Policy – Logon/Logoff Category

After navigating to the Logon/Logoff subcategory under Advanced Audit Policy Configuration, the Audit Logon policy was confirmed as set to Success and Failure, ensuring all logon events are captured in the Security log.

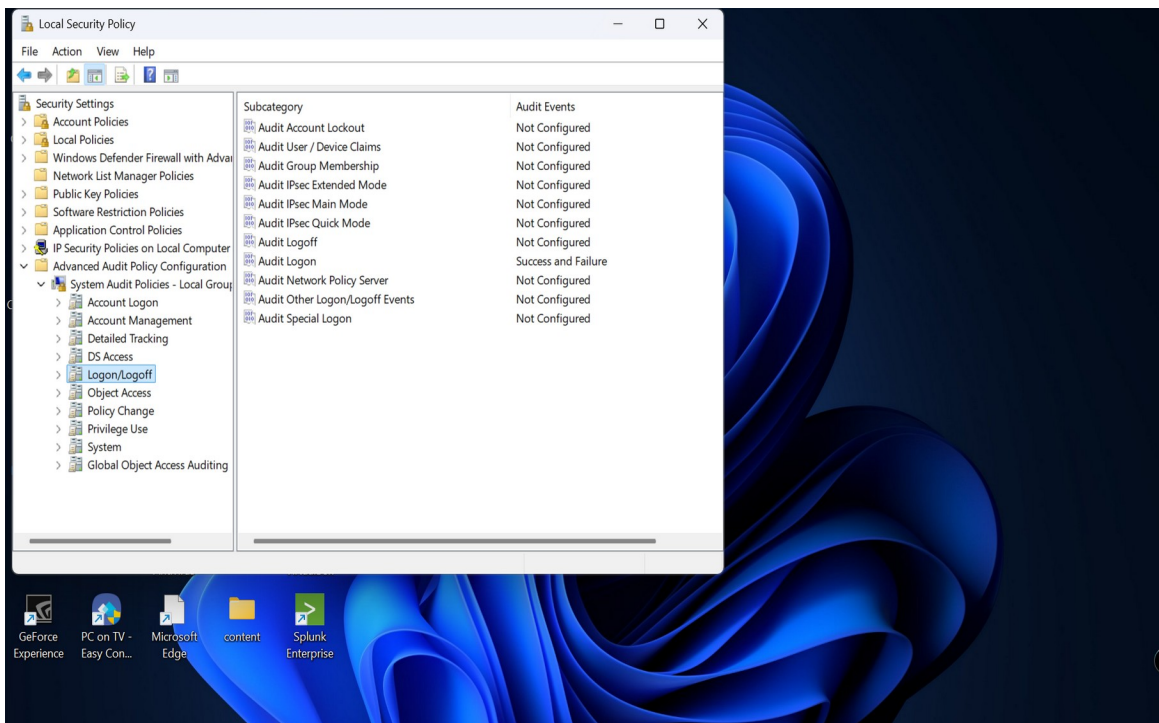


Figure 2: Advanced Audit Policy – Logon/Logoff showing Audit Logon set to Success and Failure

3.3 Audit Logon Properties

The Audit Logon Properties dialog confirmed both Success and Failure audit events are enabled. This means every logon attempt — whether it succeeds or fails — will be written to the Windows Security event log with the appropriate Event ID.

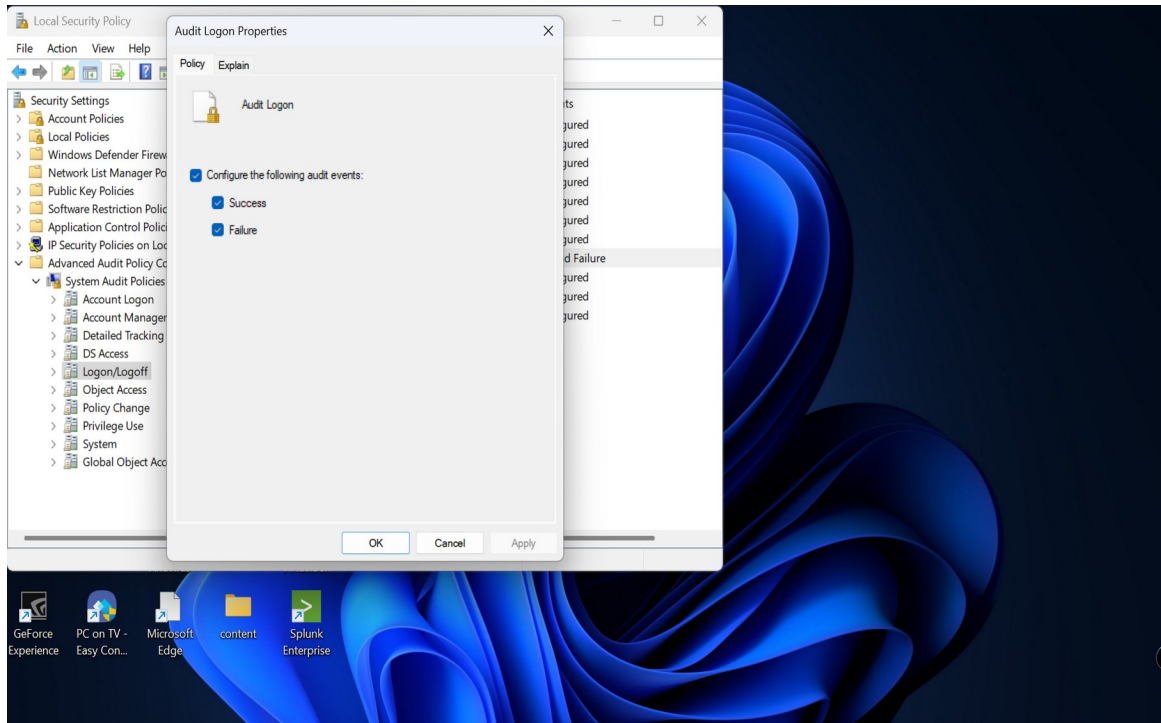


Figure 3: Audit Logon Properties – Success and Failure audit events enabled

3.4 Policy Applied via gpupdate

After saving the audit policy settings, `gpupdate /force` was executed in an elevated Command Prompt. Both Computer Policy and User Policy updates completed successfully, confirming the audit policy was applied immediately without requiring a reboot.

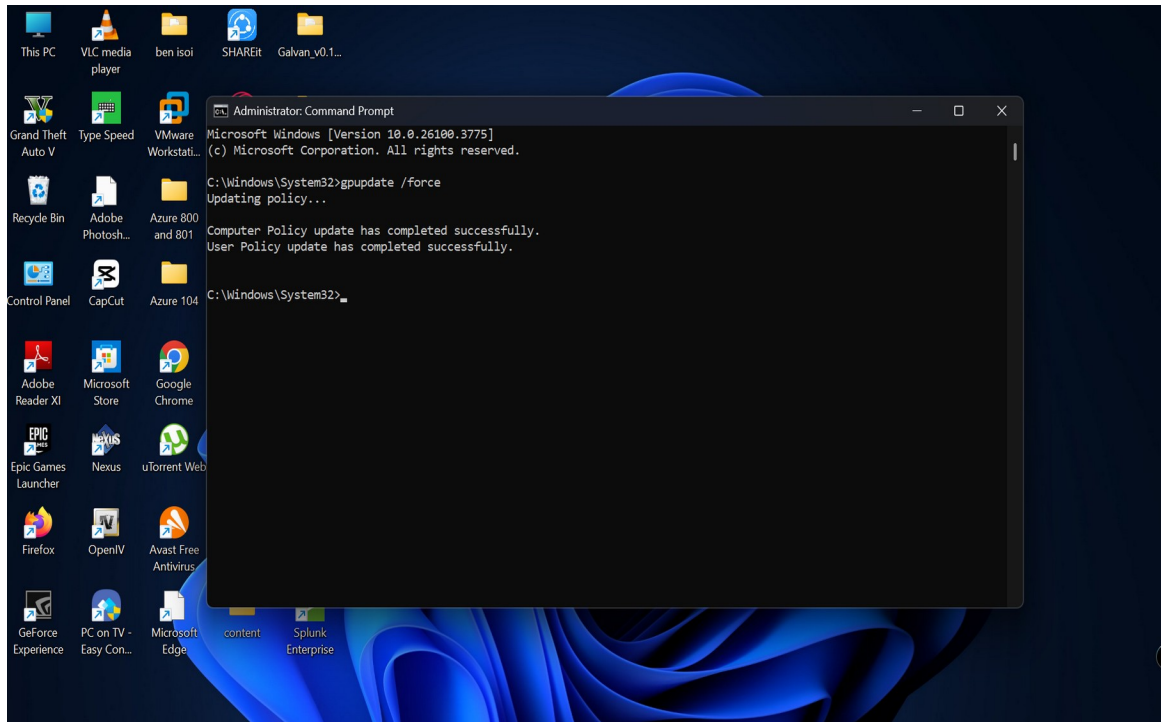


Figure 4: `gpupdate /force` executed successfully to apply audit policy

4. Baseline Verification – Event Viewer

4.1 Security Log – Event ID 4625 Confirmed

To verify auditing was working before deploying Splunk ingestion, a manual failed logon attempt was triggered by entering an incorrect password on the Windows 11 lock screen. Event Viewer (Windows Logs → Security) immediately showed the resulting Event ID 4625 (Audit Failure) alongside Event ID 4624 (successful logons), confirming the audit policy was active and logging correctly.

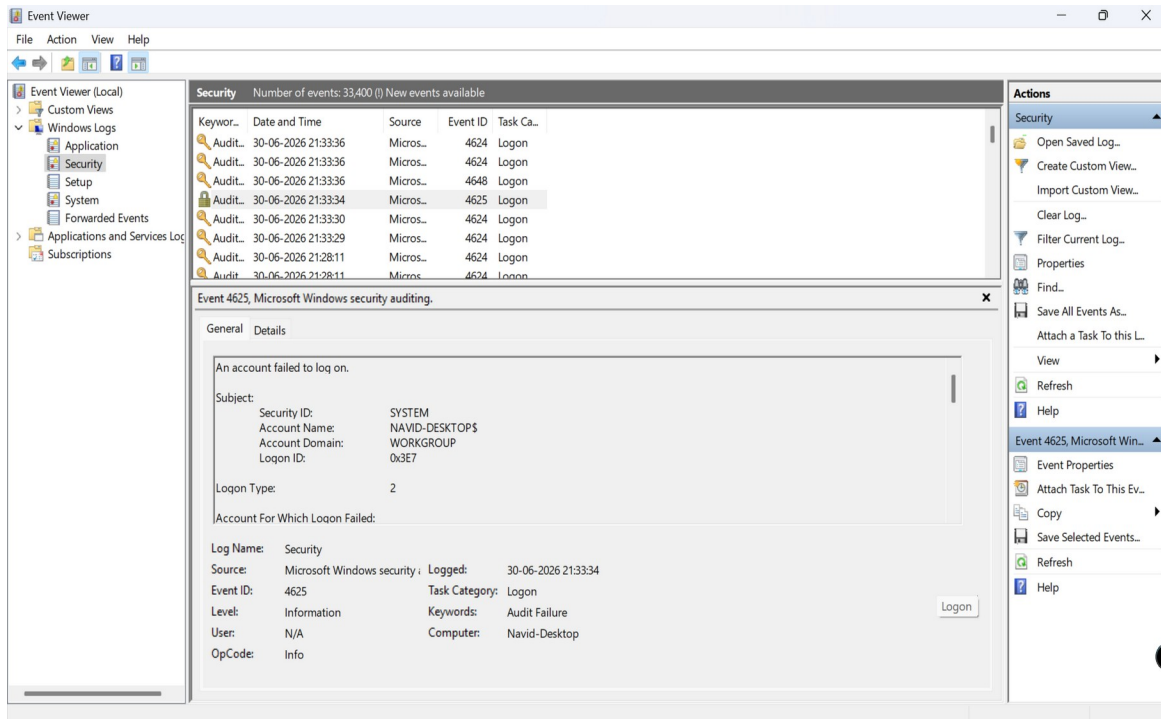


Figure 5: Event Viewer – Windows Security Log showing Event ID 4625 (failed logon)

4.2 Event 4625 – Account and Failure Details

Expanding the 4625 event revealed the full failure context: Account For Which Logon Failed showing Account Name: ASUS and Account Domain: NAVID-DESKTOP. Failure Reason was recorded as 'Unknown user name or bad password' with Status code 0xC000006D and Sub Status 0xC000006A, which are standard codes for invalid credentials.

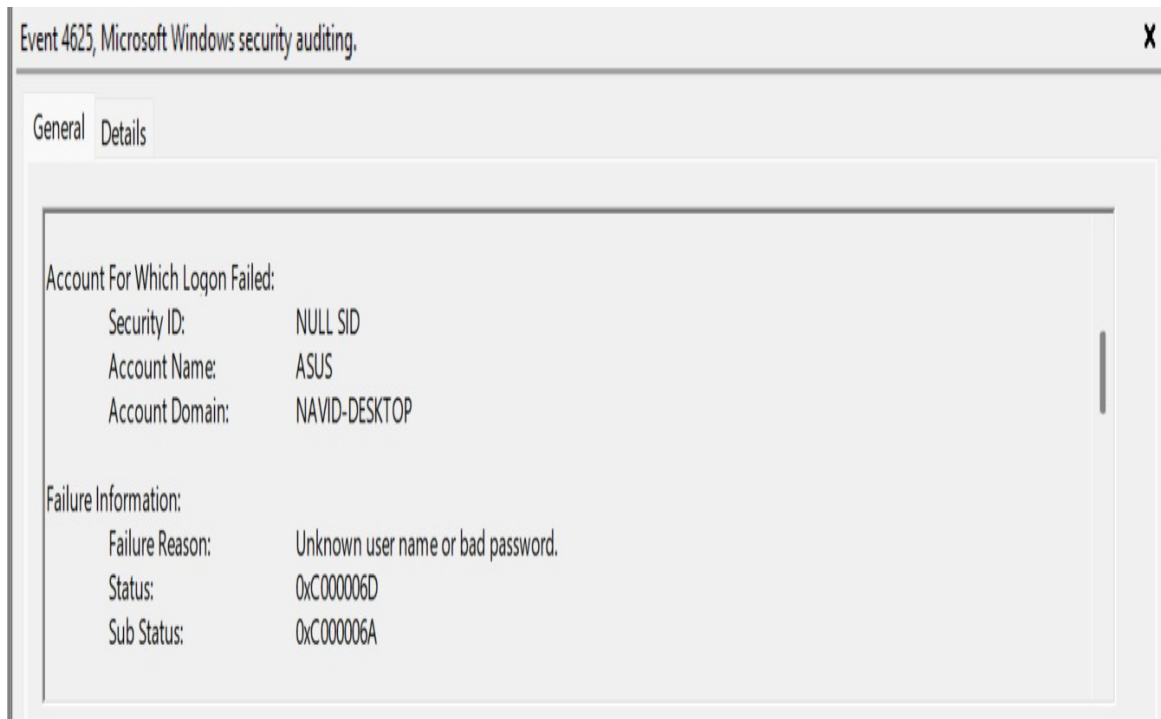


Figure 6: Event 4625 detail – Account For Which Logon Failed: ASUS, Failure Reason: Unknown user name or bad password

4.3 Event 4625 – Network Information

The Network Information section of the 4625 event showed Source Network Address: 127.0.0.1 and Workstation Name: NAVID-DESKTOP. The loopback address (127.0.0.1) is expected for this baseline test since it was a local interactive logon (Logon Type 2). Once the actual Kali-based RDP attack runs, the Source Network Address will reflect the attacker's IP (192.168.56.101).

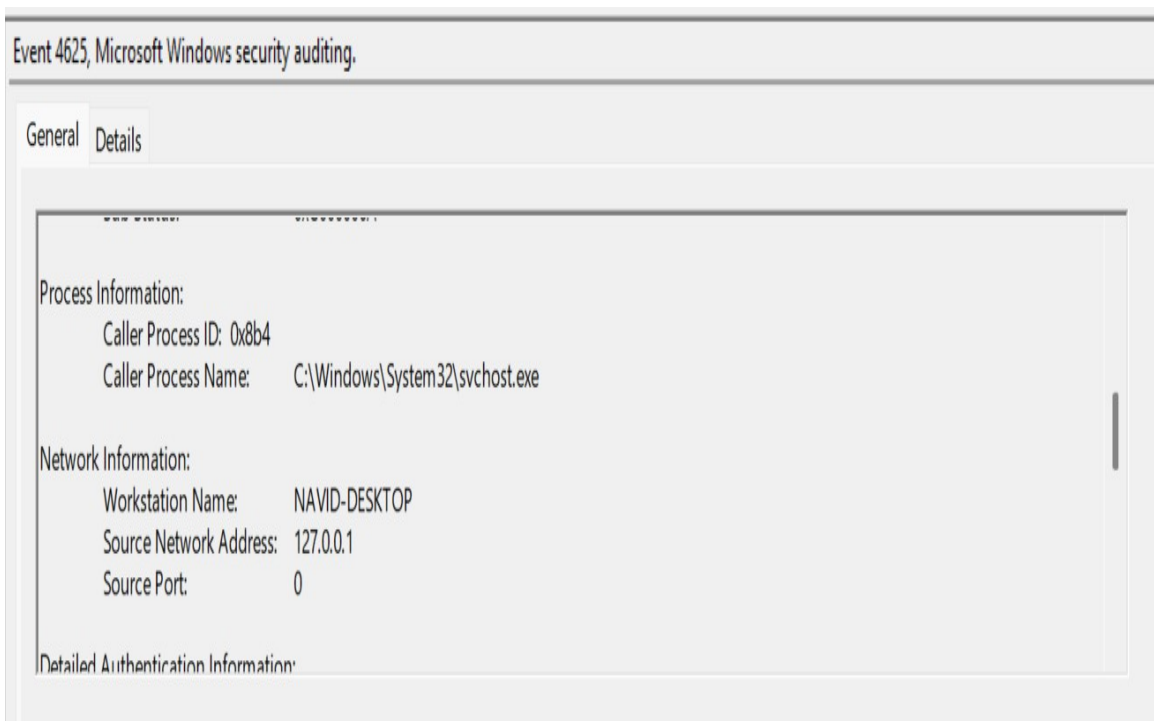


Figure 7: Event 4625 detail – Network Information: Source Network Address 127.0.0.1 (local interactive test)

4.4 Event 4625 – Authentication Details

The Detailed Authentication Information section showed Logon Process: User32, Authentication Package: Negotiate — standard values for an interactive Windows logon failure. The event footer confirms: 'This event is generated when a logon request fails. It is generated on the computer where access was attempted.'

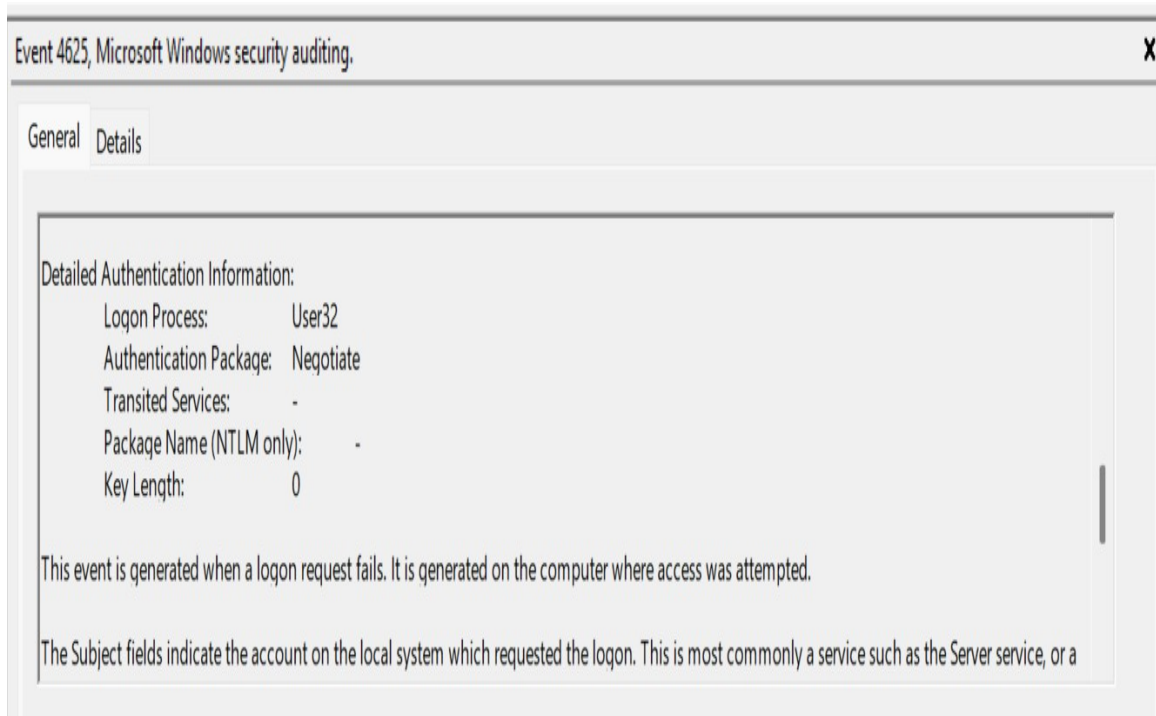


Figure 8: Event 4625 detail – Authentication Package: Negotiate, Logon Process: User32

5. Remote Desktop Configuration

Remote Desktop Protocol (RDP) was enabled on the Windows 11 host to allow the Kali attacker to simulate a network-based brute-force attack (as opposed to the local logon test above). This was done via Settings → System → Remote Desktop → Toggle ON.

With RDP enabled, the host began listening on TCP port 3389 (ms-wbt-server), making it reachable from the attacker VM over the host-only network. PC name was confirmed as Navid-Desktop.

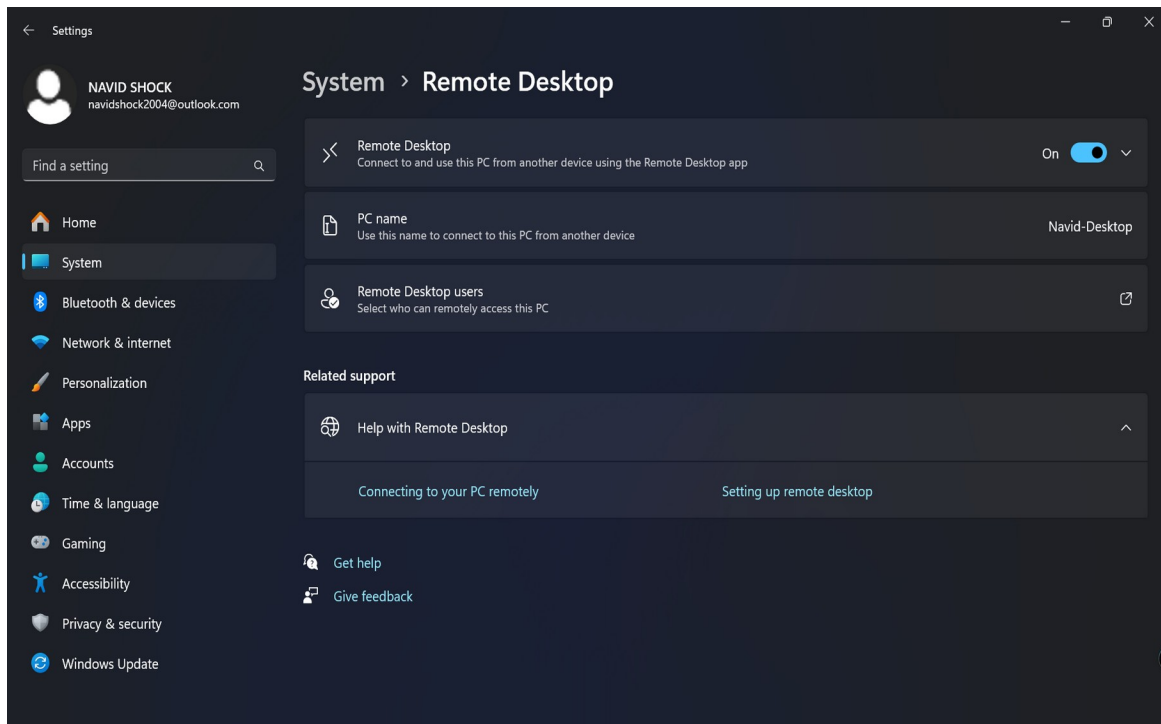


Figure 9: Windows Settings – Remote Desktop enabled on Navid-Desktop

6. Splunk Ingestion Setup

6.1 Data Inputs – Local Event Log Collection

With audit logging confirmed working in Event Viewer, the next step was ingesting the Windows Security log into Splunk Enterprise. This was done via Settings → Data Inputs → Local Event Log Collection. No Universal Forwarder was required since Splunk Enterprise is installed directly on the Windows 11 host.

Note: During this step, a disk space alert was encountered — Splunk paused indexing because the C: drive fell below the 5000MB minimum free space threshold. This was resolved via Windows Disk Cleanup before proceeding.

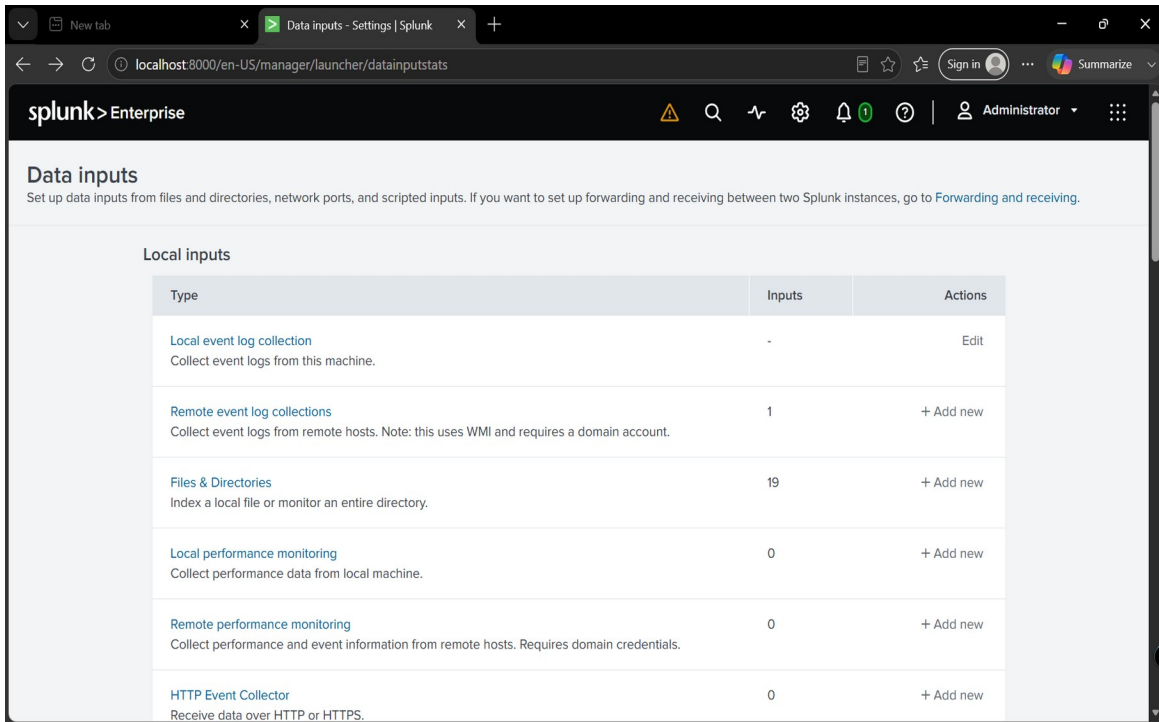


Figure 10: Splunk Data Inputs page – Local Event Log Collection configured

6.2 Security Log Selected – Index: main

In the Event Log Collections configuration page, the Security log was selected from the available logs list and moved to the Selected log(s) column. The destination index was set to main (consistent with Labs 1-3) to keep all lab data consolidated. Settings were saved and Splunk began ingesting Windows Security events.

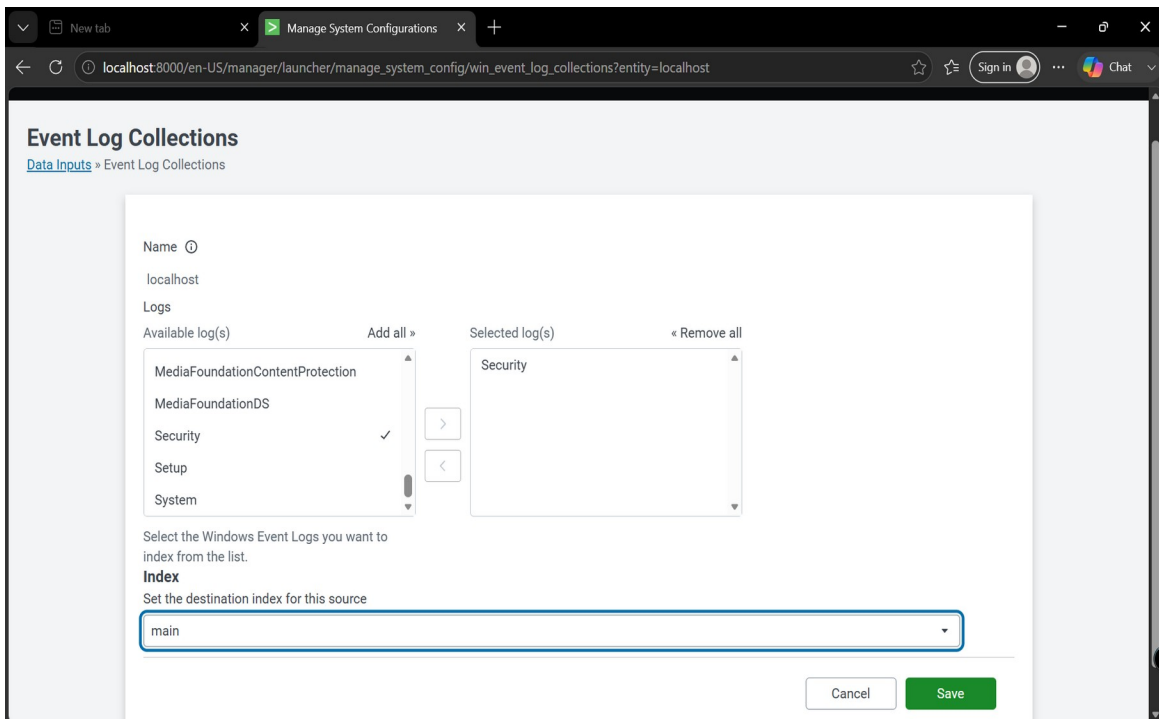
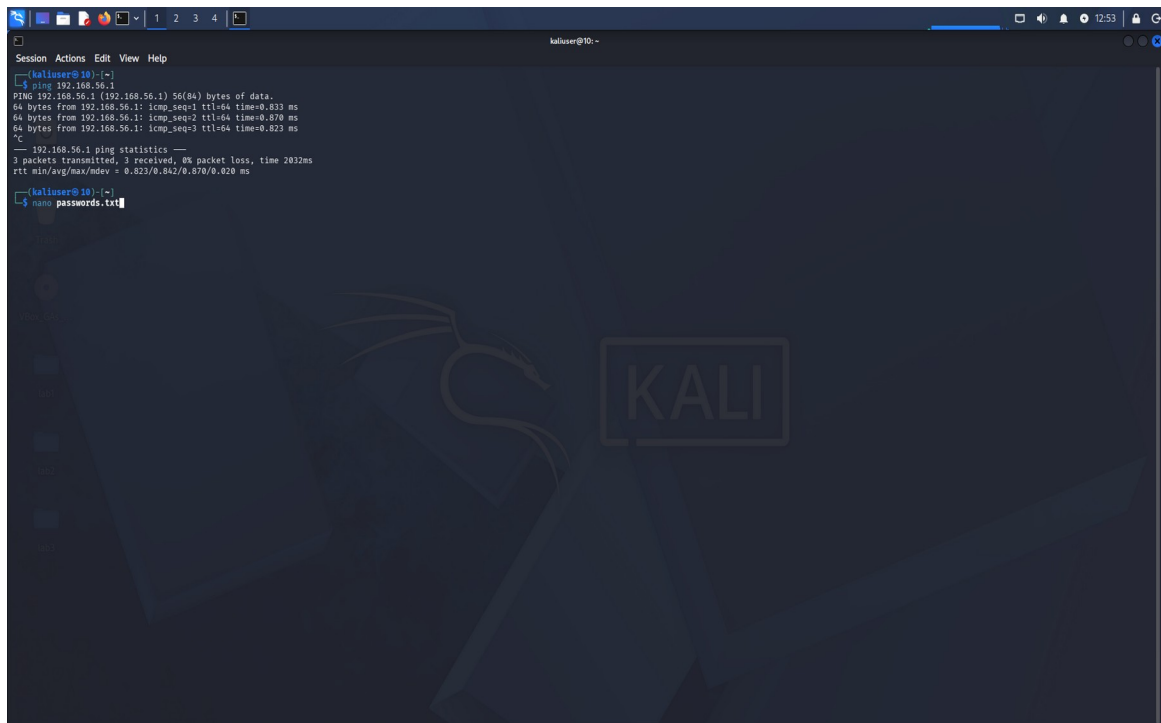


Figure 11: Event Log Collections – Security log selected, index set to main

7. Attack Simulation from Kali Linux

7.1 Network Connectivity Verification

Before launching the brute-force attack, connectivity to the target Windows 11 host was verified from the Kali Linux VM. A ping test to 192.168.56.1 confirmed stable host-only network connectivity with 0% packet loss and sub-millisecond response times. A password wordlist file (passwords.txt) was then created using the nano text editor.



```
Session Actions Edit View Help
kaliuser@10: ~
kaliuser@10:~$ ping 192.168.56.1
PING 192.168.56.1 (192.168.56.1) 56(84) bytes of data:
64 bytes from 192.168.56.1: icmp_seq=1 ttl=64 time=0.832 ms
64 bytes from 192.168.56.1: icmp_seq=2 ttl=64 time=0.878 ms
64 bytes from 192.168.56.1: icmp_seq=3 ttl=64 time=0.823 ms
^C
--- 192.168.56.1 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2032ms
rtt min/avg/max/mdev = 0.823/0.842/0.878/0.020 ms
kaliuser@10:~$ nano passwords.txt
```

Figure 12: Kali Linux – Ping connectivity confirmed to 192.168.56.1, nano passwords.txt created

7.2 Password Wordlist

A custom password wordlist was created in /home/kaliuser/passwords.txt containing common weak passwords alongside the actual target account password. This simulates a real-world dictionary attack where an attacker tries commonly used passwords before attempting the correct one, generating multiple failed logon events in the Security log.

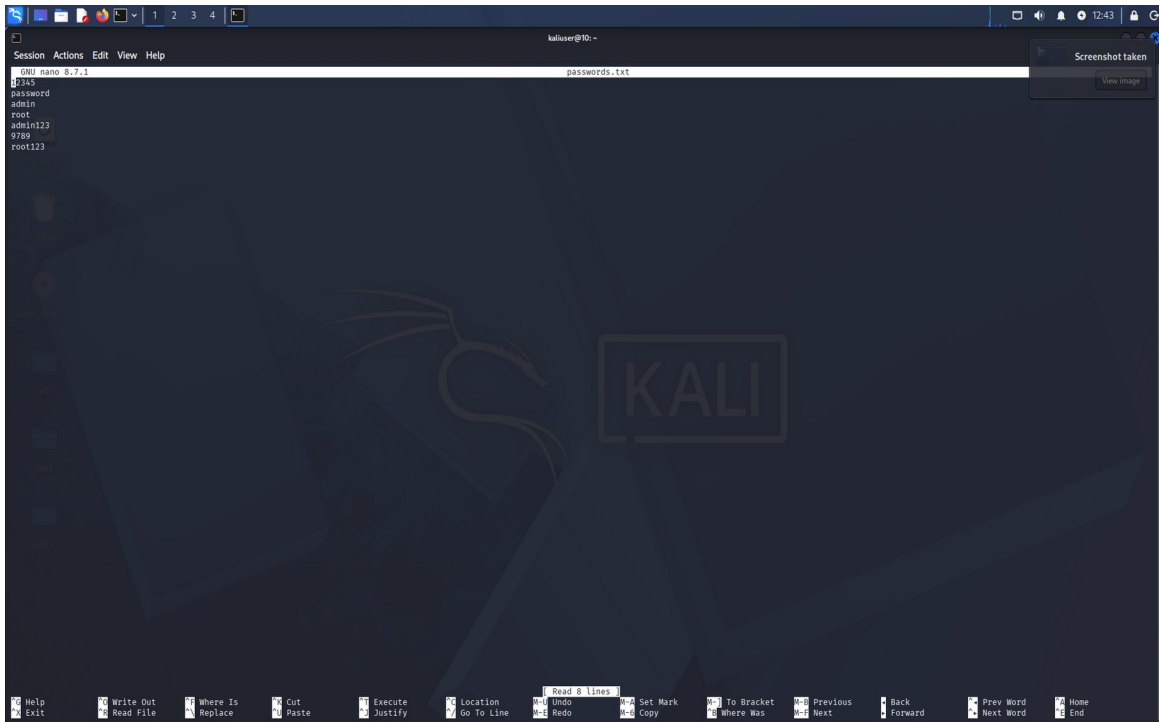


Figure 13: Kali Linux – Password wordlist (passwords.txt) contents in nano editor

7.3 RDP Port Reachability – Nmap Scan

Before launching Hydra, an Nmap scan was run to confirm TCP port 3389 was open and accessible on the target:

```
nmap -p 3389 192.168.56.1
```

The scan confirmed: 3389/tcp open ms-wbt-server — RDP is listening and reachable from the Kali attacker VM. This screenshot also documents the pre-attack reconnaissance phase, a critical step in understanding the attacker's perspective.

Note: SMB brute force (port 445) was attempted first using Hydra and Crowbar, but both tools were incompatible with the modern SMB2/3 signing enforcement on Windows 11. The attack vector was pivoted to RDP, which is also a more common real-world scenario for SOC analysts to detect.

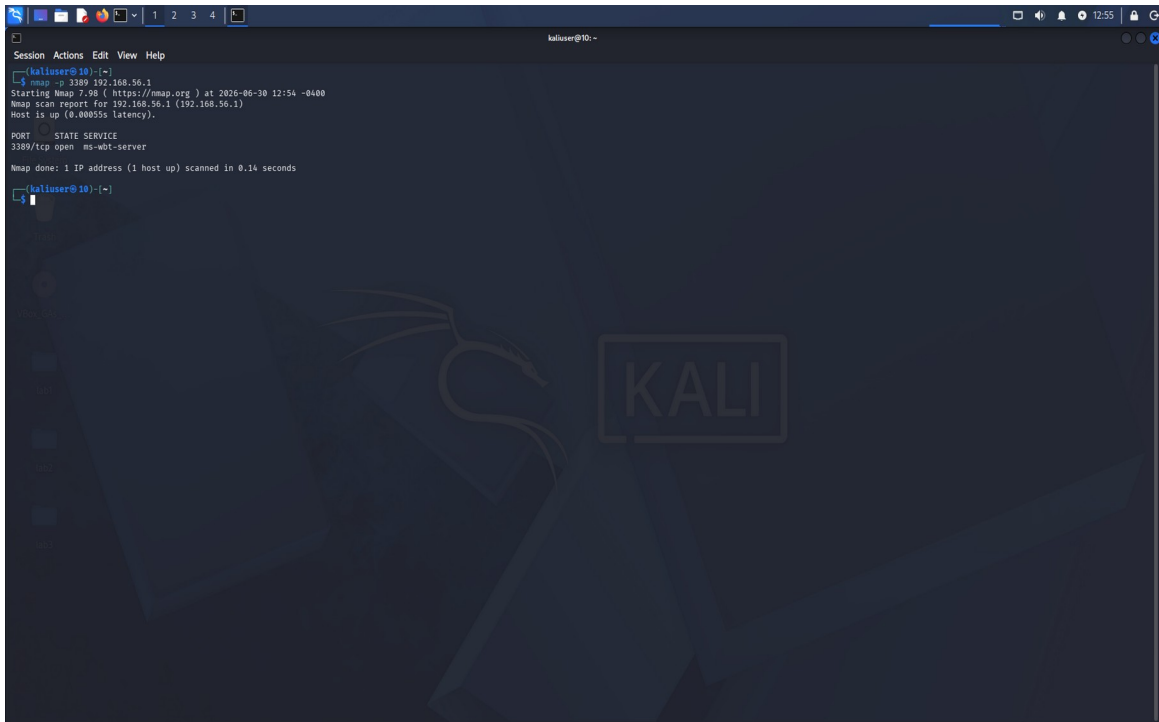


Figure 14: Kali Linux – Nmap scan confirming port 3389 (RDP) open on target 192.168.56.1

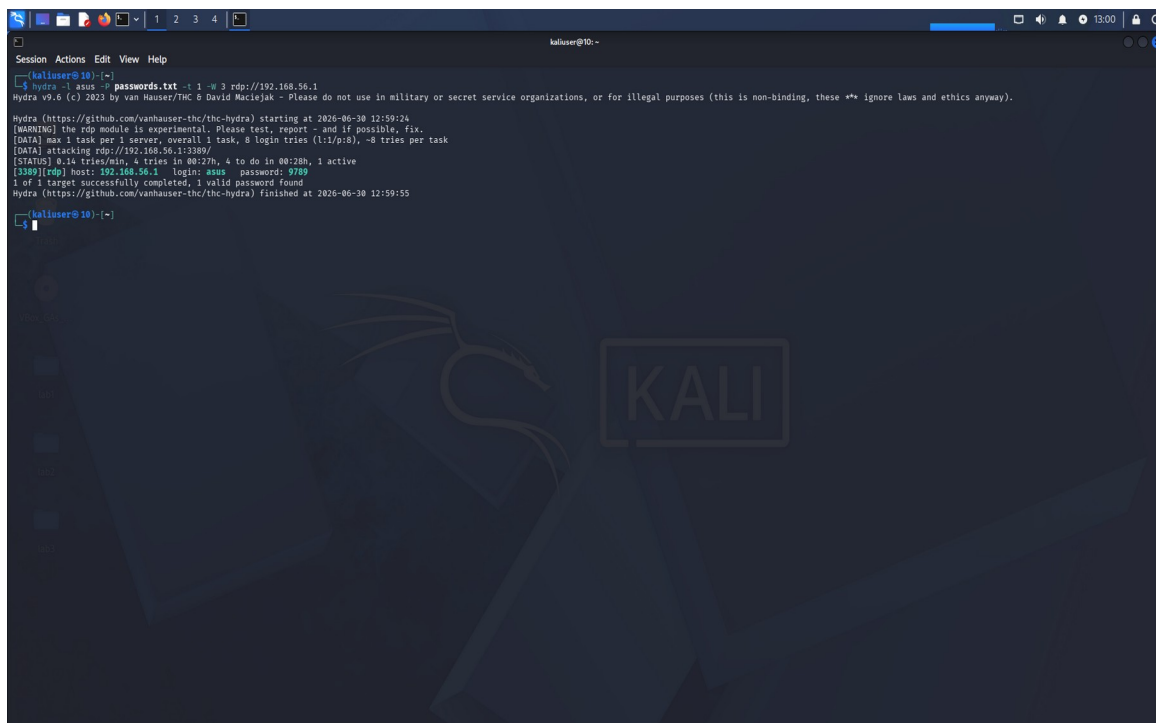
7.4 Hydra RDP Brute-Force Attack

The Hydra password-cracking tool was used to simulate an RDP brute-force attack against the asus account on the Windows 11 host. Throttle flags were used to reduce parallel connections (as required by the RDP protocol):

```
hydra -l asus -P passwords.txt -t 1 -W 3 rdp://192.168.56.1
```

Hydra successfully discovered valid credentials — login: asus / password: 9789 — after attempting multiple incorrect passwords. This generated a series of Event ID 4625 (failed logon) events in the Windows Security log, followed by a 4624 (successful logon) upon credential discovery.

Security Note: The discovery of a 4-digit numeric password during this lab highlights a real-world risk — weak credentials are one of the primary reasons RDP brute-force attacks succeed in live environments.



```
Session Actions Edit View Help
kaliuser@10: ~
kaliuser@10:~$ hydra -l asus -P passwords.txt -w 3 rdp://192.168.56.1
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-30 12:59:24
[WARNING] the rdp module is experimental. Please test, report - and if possible, fix.
[DATA] max 1 task per 1 server, overall 1 task, 8 login tries (1:1/p:8), ~8 tries per task
[DATA] attacking rdp://192.168.56.1:3389/
[STATUS] 0.14 tries/min, 4 tries in 00:27h, 4 to do in 00:28h, 1 active
[3389][rdp] host: 192.168.56.1 login: asus password: 9789
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-06-30 12:59:55

kaliuser@10:~$
```

Figure 15: Hydra RDP brute-force attack – valid credential found: login: asus / password: 9789

8. Detection via Splunk SPL

8.1 Raw Event Search – 14 Failed Logon Events Detected

After the Hydra attack completed, Splunk was queried to verify that the failed logon events were captured. The following SPL search was run with a 24-hour time window:

```
index=main sourcetype="WinEventLog:Security" EventCode=4625
Account_Name=asus
```

The search returned 14 matching events in the 10:57 PM timeframe, directly correlating with the Hydra attack window. Key fields confirmed: LogName=Security, EventCode=4625, ComputerName=Navid-Desktop, sourcetype=WinEventLog:Security.

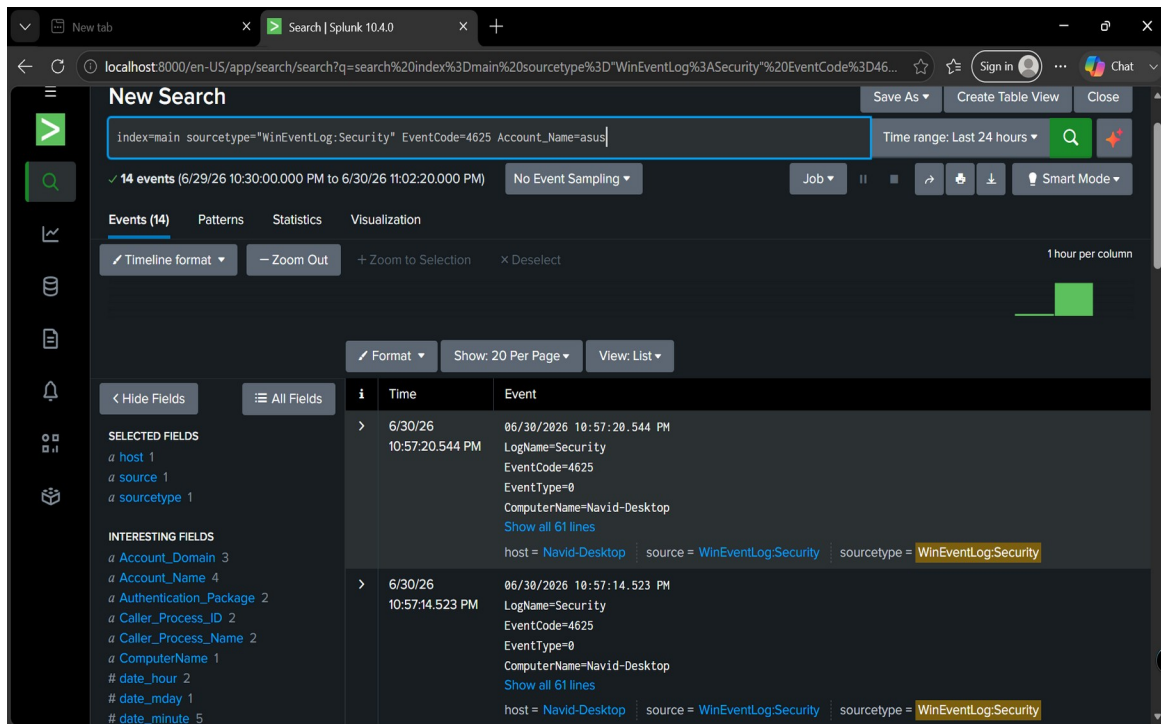


Figure 16: Splunk – 14 EventCode=4625 events for Account_Name=asus detected within attack window

8.2 Statistics Query – Threshold Breached

A more analytical SPL query was run to aggregate the failed logon counts by account and process, simulating a real SOC detection rule:

```
index=main sourcetype="WinEventLog:Security" EventCode=4625 | stats
count by Account_Name, Caller_Process_Name | where count > 5
```

The results showed the asus account had 13 failed logon attempts, well above the detection threshold of 5. Caller_Process_Name was empty (-) for the RDP-originated events, which is a known field behavior for network-based logon failures versus local interactive logons — this distinction is worth noting in SOC investigation workflows.

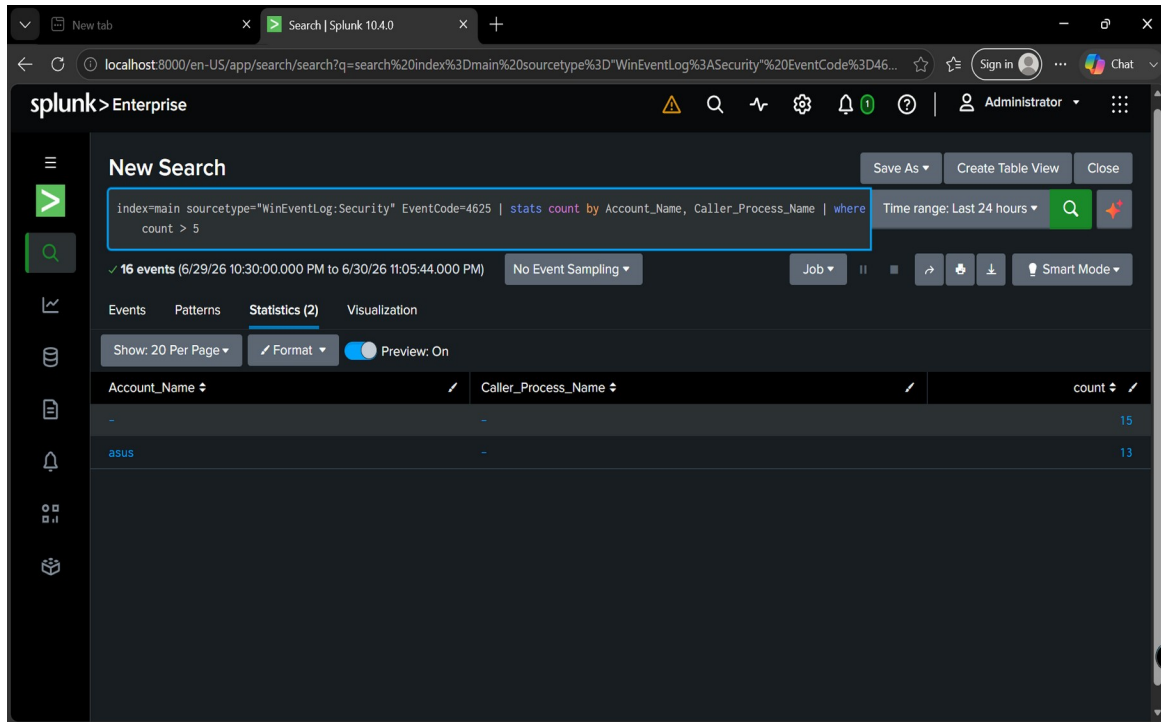


Figure 17: Splunk SPL stats query – asus account: count 13 failed logons, exceeding threshold of 5

9. Splunk Alert Configuration

9.1 Save As Alert – Settings

The detection SPL query was saved as a scheduled alert named 'RDP brute force detection - failed logons'. Alert settings configured:

- Title: RDP brute force detection - failed logons
- Alert Type: Scheduled — Run every hour
- At: 0 minutes past the hour
- Expires: 24 hours

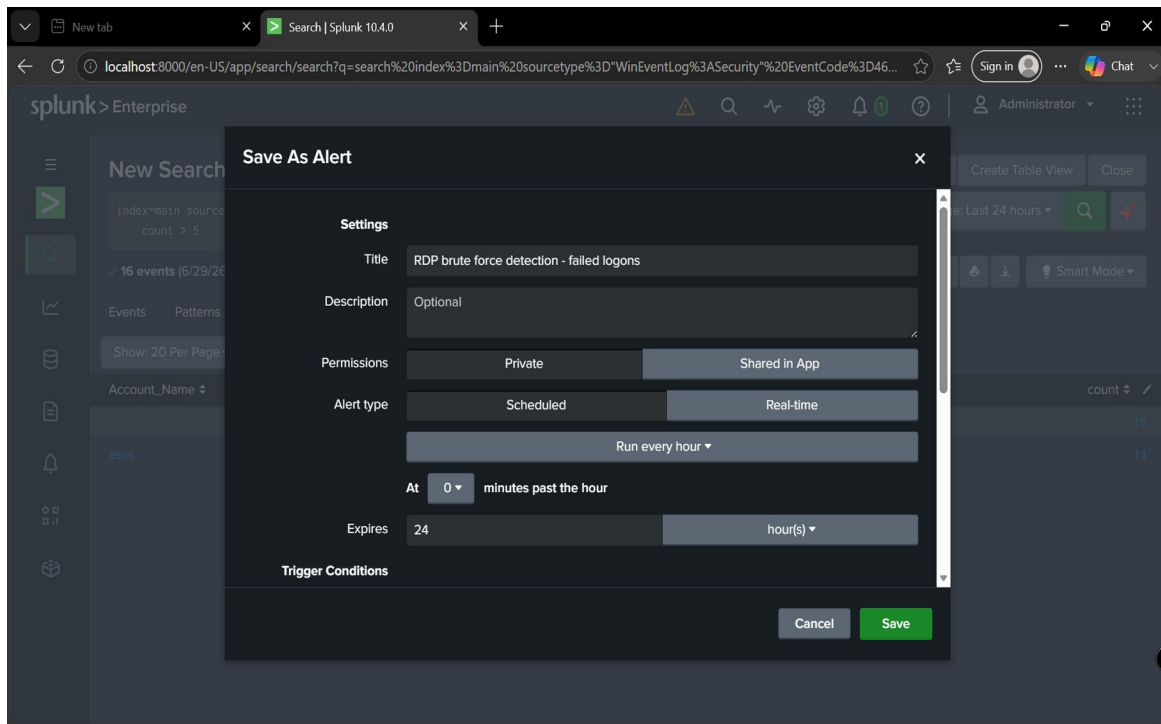


Figure 18: Save As Alert dialog – Title: RDP brute force detection - failed logons, Scheduled hourly

9.2 Trigger Conditions and Actions

The alert trigger conditions were configured to fire whenever the SPL query returns any results (i.e., when account count > 5 is already filtered by the where clause, any output means a brute-force threshold was exceeded):

- Trigger alert when: Number of Results is greater than 0
- Trigger: For each result
- Action: Add to Triggered Alerts
- Severity: Medium

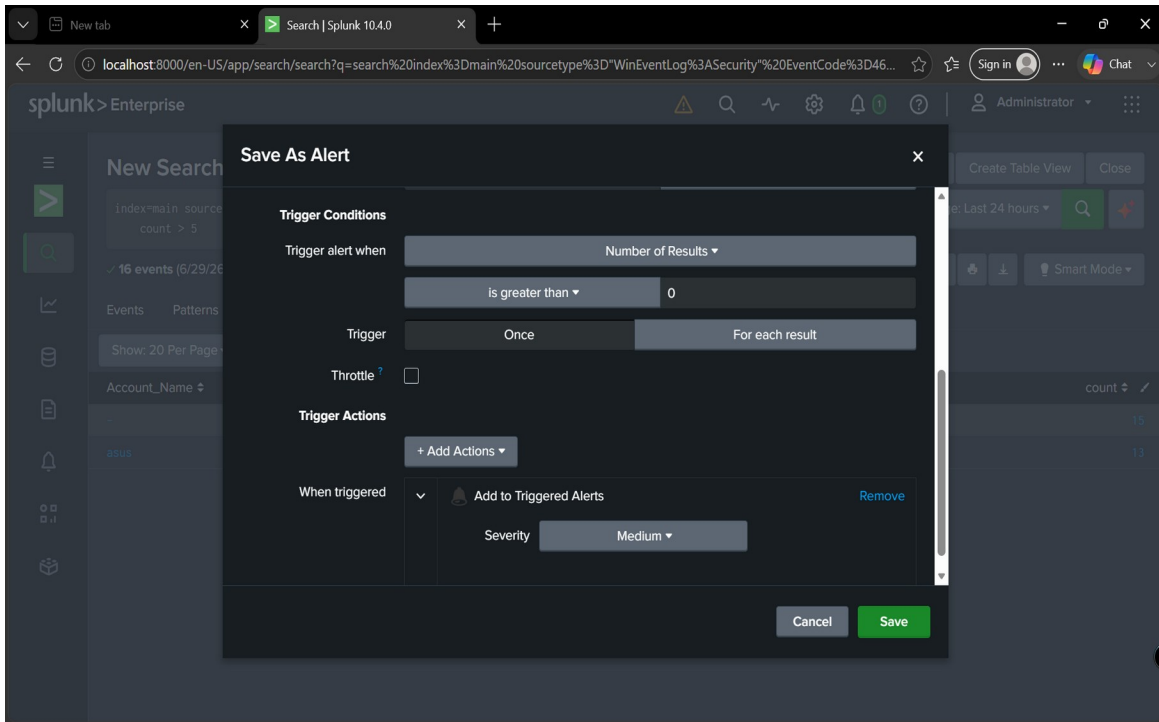


Figure 19: Alert Trigger Conditions – Number of Results > 0, Action: Add to Triggered Alerts (Severity: Medium)

9.3 Alert Saved and Active

The alert was saved and confirmed as active with the following configuration summary visible in the Splunk Searches, Reports, and Alerts dashboard:

- Enabled: Yes
- Alert Type: Scheduled. Hourly, at 0 minutes past the hour
- Trigger Condition: Number of Results is > 0
- Actions: Add to Triggered Alerts
- Permissions: Private. Owned by navid

The alert is now monitoring the Windows Security event log on an hourly basis and will fire whenever more than 5 failed logon attempts are detected for any account — automatically alerting the SOC analyst to a potential brute-force attack in progress.

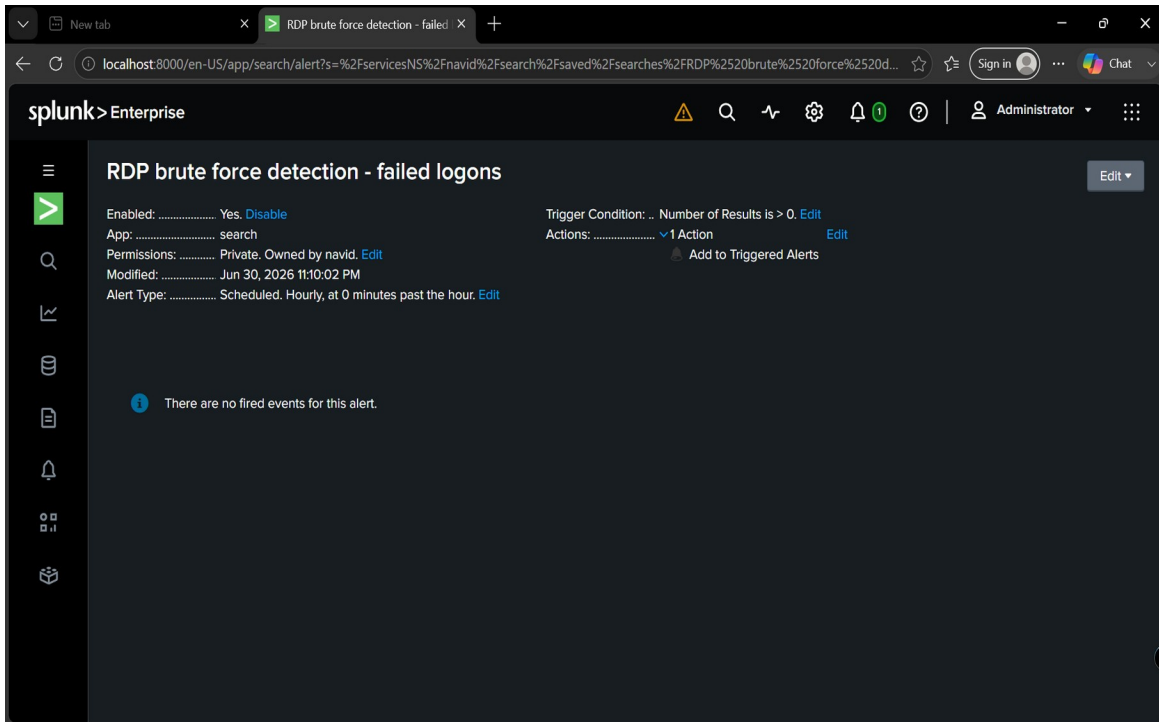


Figure 20: Saved alert confirmation – RDP brute force detection - failed logons, Enabled, Scheduled hourly

10. MITRE ATT&CK Mapping

The following table maps the techniques observed in this lab to the MITRE ATT&CK framework (Enterprise):

Tactic	Technique ID	Technique Name	Observed Activity	Detection
Reconnaissance	T1046	Network Service Scanning	Nmap scan on port 3389 to confirm RDP is open on 192.168.56.1	Nmap output showing 3389/tcp open ms-wbt-server
Credential Access	T1110	Brute Force	Hydra used to systematically attempt passwords against the RDP service	Event ID 4625 – multiple failed logons within short time window
Credential Access	T1110.001	Brute Force: Password Guessing	Dictionary attack using passwords.txt with common weak passwords	13+ EventCode=4625 events for account 'asus' in Splunk
Lateral Movement	T1021.001	Remote Services: Remote Desktop Protocol	Attacker targeted RDP (TCP 3389) as the entry point for brute force	Splunk alert: RDP brute force detection - failed logons
Defense Evasion / Persistence	T1078	Valid Accounts	Successful credential discovery (asus:9789) enabling legitimate RDP access	Event ID 4624 – successful logon following 4625 series

11. Key Findings and Lessons Learned

10.1 Detection Summary

Lab 4 successfully demonstrated an end-to-end detection pipeline for Windows-based brute-force attacks using native Windows auditing and Splunk SIEM:

- Audit policy (secpol.msc) enabled Event ID 4625 logging for all failed logon attempts
- Splunk ingested the Security event log via Local Event Log Collection (no Universal Forwarder required when Splunk is on the same host)
- Hydra RDP brute force generated 13+ failed logon events, all captured in Splunk
- SPL detection query correctly identified the attack and an alert was created for ongoing monitoring

10.2 Technical Notes

- SMB brute force (Hydra, Crowbar) failed against Windows 11 due to SMB2/3 signing incompatibility — both tools only support legacy SMB1. This is a real-world attacker friction point.
- RDP-originated 4625 events do not populate Caller_Process_Name, unlike local interactive logon failures — important for tuning detection queries in production SOC environments.
- Splunk's 5000MB free disk space minimum caused an indexing pause mid-lab, demonstrating the importance of monitoring SIEM infrastructure health alongside security detections.
- Weak credentials (4-digit numeric password) were discovered organically during the lab — a realistic illustration of why brute-force attacks succeed and why account password policies matter.

10.3 Relevance to SOC L1 Role

This lab reflects core SOC L1 analyst skills: configuring Windows audit policies, understanding Security event IDs (4624/4625), ingesting logs into a SIEM, writing detection queries, and setting up automated alerts. RDP brute force detection is one of the most common alert types encountered in real SOC environments, making this lab directly applicable to day-one analyst tasks.

12. References

- Microsoft Docs – Windows Security Auditing: Event ID 4625
- Splunk Documentation – Windows Event Log Inputs (Splunk Enterprise 10.x)
- THC-Hydra GitHub – <https://github.com/vanhauser-thc/thc-hydra>
- GitHub Repository – <https://github.com/mdnavid2004-bit/cybersecurity-home-lab>